

UAM Administration Guide - 6.0.1-GA (AI)

Table of Contents

1. Preface - UAM Administration Guide.....	3
2. Introduction to UAM Administration.....	4
3. UAM Configuration via Admin Console.....	5
4. AccessMatrix Single-Sign-On (SSO) Portal.....	21
5. UAM Federated SSO.....	22
5.1. UAM Federated SSO via OAuth 2.1 and OIDC.....	23
5.2. UAM Federated SSO via SAML.....	28
5.3. UAM Federated SSO via JWT Authentication.....	45
6. Cache Provider.....	50
7. Appendices.....	52

1. Preface - UAM Administration Guide

This reference guide contains instructions on how to administer the AccessMatrix Universal Access Management (abbr. as UAM) system.

Intended Reader

This is intended as a reference for the security administrator.

Document Scope

This document provides instructions on how to perform administrative tasks using the AccessMatrix UAM product.

For feedback or questions regarding this document, contact doc@i-sprint.com.

Related Documents

For more information, see the following documents in the AccessMatrix Product Suite:

- [*AccessMatrix Release Notes*](#)
 - [*AccessMatrix Common Administration Guide*](#)
 - [*UAM WSA Reverse Proxy Implementation Guide*](#)
 - [*UAM OAuth and OIDC Implementation Guide*](#)
 - [*UAM OIDC Relying Party Implementation Guide*](#)
 - [*UAM SAML Identity Provider Implementation Guide*](#)
 - [*AccessMatrix SSO Portal Implementation Guide*](#)
 - [*AccessMatrix SSO Portal User Guide*](#)
-

2. Introduction to UAM Administration

UAM provides Web Single-Sign-On (SSO) and Federated SSO (SAML, OAuth/OpenID Connect, JWT) to allow a user to have seamless access between multiple applications or an application with distributed architecture (microservices). On top of this, UAM also provides policy-driven access control protect access to both web and non-web application resources.

For a Web Single-Sign-On (SSO) solution, Web Security Agent (WSA) reverse proxy is the technology used to secure access to the web resources based on the access control policy defined by the security administrators. With Web Security Agent, HTTP request headers can be set via user information response configuration. Alternatively, an application may also call UAM web service APIs to evaluate whether a user is allowed to access resources based on the configured policy.

3. UAM Configuration via Admin Console

The following sections provide information on the configurations that can be performed when using UAM.

User Response Configuration

By configuring the User Response, user info can be returned upon the successful completion of certain SSO use cases. These include:

i **Note:** For more details on how to configure the User Response, refer to [Common Administration Guide - Configure User Response](#).

- WSA login
 - Certain user-specific information pertaining to the configured user response can be returned when the user has successfully granted access to the resource URL.

i **Note:** For more details on the deployment of Web SSO and how this can be configured, refer to the [UAM WSA Reverse Proxy Implementation Guide](#).

- OIDC authentication flow
 - User info can be returned in the ID token, authorization code, refresh token, or from the user info endpoint. Multiple claims can be configured. The claim names can be specified with **Name (Claim Name)**.
 - User Response can also be used to configure the retrieval of user identity (Id token subject retrieval).
- SAML web browser SSO authentication flow
 - SAML Response Assertion attributes can be retrieved from the User Response object. Multiple attributes can be configured. The assertion attribute names or assertion friendly names can be specified with **Name (Claim Name)**
 - User response can also be used to configure the retrieval of user identity (NameID subject retrieval).

Basic User Fields and User Info Attributes

Under the **Basic User Fields and User Info Attributes** section, select an attribute using the drop-down list corresponding to the **Attribute Name**. The **Attribute Name** refers to the attribute whose value can be retrieved from the user, session, web SSO's access agent and user, or OIDC token and user.

The following table lists supported attributes that are specific to AccessMatrix UAM:

i **Note:** For more details on the rest of the attributes, refer to the [AccessMatrix Common Administration Guide - Basic User Fields and User Info Attributes](#).

Attribute Name	Attribute Value Sources	Description
OIDCAddressClaim	User	The address claim value (OIDC) of the user response.
OIDCAuthenticatedRealmId	OIDC Token	The user's authenticated realm Id based on the user's recent authentication event associated with the OIDC token.
OIDCLastSuccessfulLoginDate	OIDC Token	The user's last successful login date prior to the user's recent authentication event associated with the OIDC token.
OIDCLastFailedLoginDate	OIDC Token	The user's last failed login date prior to the user's recent authentication event associated with the OIDC token.

Web Security Agent Configuration

To locate the **Web Security Agent Configuration** page, navigate to **Administration Dashboard > Configuration > Unified SSO > Web SSO > Web Security Agent Configuration**.

Select **Edit**. On the **Edit Configuration** page, the administrator can define the list of file extensions for URLs that WSA will not intercept during URL access to ensure performance, as well as the list of regular expressions to be rejected by WSA, which is useful against cross-site scripting attack or hacking via passing special characters to the web server.

The administrator must restart the target web application server in which WSA resides for any changes made to take effect.

Security Policy	Default Value	Remark
File extensions to ignore	.jpg .gif .js .css .png .jpeg .ico .bmp	A list of file extensions for URLs that WSA will not intercept (case insensitive) to ensure performance
Illegal URL Patterns	\\.\\V	A list of regular expressions that indicate illegal URL patterns to be rejected by WSA

Security Policy	Default Value	Remark
Session cookie scheme	Default: AccessMatrix 5 Default Session Cookie	Controls the format and management of session cookie in WSA

Application Policy Configuration

Application Policy can be used by federated applications to whitelist specific authentication methods for users. When configured, it validates if the session token has been authenticated according to a set of whitelisted attributes:

i Note: The application policy can only be applied when UAM acts as the federated SSO Identity Provider (IdP) or authorization server.	
Attribute	Description
Enforce Policy	If specified as "true", the application policy will enforce the whitelisted Login Authentication Realms and Reauthentication Login Modules attributes before generating the authentication assertion.
Login Authentication Realms (Press Ctrl + Click to select multiple options)	The login authentication realms that will be whitelisted.
Reauthentication Login Modules (Press Ctrl + Click to select multiple options)	The reauthentication login modules that will be whitelisted.
Enable Grace Period for Ignoring Reauthentication Login Module	If specified as "true", reauthentication will be bypassed if the user has been authenticated within the last 30 seconds during the OAuth or SAML request.

To configure the application policy, perform the following:

1. Navigate to the **Administration Dashboard > Security Policy > Unified SSO > Federated SSO > Application Policy** and click on **Identity Provider Policy**.
2. Click **Create**, select the relevant protocol using the dropdown list corresponding to **Implementation**, and click the **Next** button.
3. Enter the Identity Provider Policy Id (e.g. SAMLAppPolicy) and Identity Provider Policy Name (e.g. SAML App Policy).
4. Set the **Enforce Policy** attribute to "true".

-
5. Specify the whitelisted values for the **Login Authentication Realms** and **Reauthentication Login Modules** attributes.



Note: Press Ctrl + Click to select multiple values.

6. (Optional) Set the **Enable Grace for Reauthentication** attribute to "true".
7. Click the **Save** button.

Access Agent Configuration

In UAM, there are three types of access agents, i.e. "Application Security Agent", "Physical Access Application", and "Web Security Agent" to provide policy-driven access control to protect access to the applications.

The list of access agents is controlled by the **Application Type** license granted to the server for UAM features.

- **For Web Applications**

With UAM's Web Security Agent (WSA), access to the web resources within web servers can be protected based on the access control policy defined by the security administrators. Access control information can also be retrieved via HTTP header information. This enables organizations to provide fine-grain access control on Web resources.

- **For Non-Web Applications**

UAM provides a set of security APIs (a.k.a. XML-RPC APIs) for developers to tightly integrate both Web and non-Web applications. With UAM's Application Security Agent (ASA), access to the resources within application servers is protected based on the access control policy defined by the security administrators. This policy-driven approach greatly simplifies user administration and application integration.

For each type of applications, the administrator is provided with a function to define the desired application roles. These application roles are governed by the access permission rules that define which application role is requested to perform which method on which resource of the application.

- **Dynamic (System-Defined) Application Role**

These are dynamic (system-defined) application roles and meant to be shared by all the applications.

- **Private Application Role**

These are user-defined application roles and are defined inside the particular application itself. They are private to the application itself and cannot be shared by other applications.

To locate the **Access Agent** page, navigate to **Administration Dashboard > Configuration > Unified SSO > Web SSO > Access Agent**. The following tasks can be performed on the **Access Agent** page:

- **Create** access agent - Click **Create** and select the desired implementation type from the **Implementation** drop-down list, and then click **Next** to display the **Create Access Agent** page. Enter the details and save.
- **Search** an existing access agent - Agents can be searched by entering an access agent Id, an access agent name and/or a segment. All available access agents are displayed by default.
- **View** an existing agent - Click an access agent Id under the **Search Access Agent Result** page to view its details.
- **Edit** access agent - Click **Edit** on the **View Access Agent** page to modify the details and save.
- **Delete** access agent - Click **Delete** on the **View Access Agent** page and select **OK** on the Confirm dialog box.

**Notes:**

- The search can be based on a wildcard (*) or exact phrase match and is case-sensitive.
e.g. If "DEMO*" is entered for a search field, the entry with an Id of "DEMO123" will be retrieved, however, not "123DEMO". Enter "*DEMO" to retrieve "123DEMO", or leave the search field blank to search for all available results.
- The search criterion is also based on 'AND' condition.
e.g. If the administrator enters values for both **Id** and **Name** fields, then only the results matching both values will be retrieved.

View Access Agent Page Attribute Description**Note:** ' * ' denotes mandatory attribute.

Attribute Name	Description
*Access Agent Id	Unique Id of access agent.
*Access Agent Name	Name of access agent.

Attribute Name	Description
Description	Description of access agent.
Implementation	Type of access agent implementation.
Access Agent Type	Types of access agents, i.e. "Application Security Agent", "Physical Access Application", and "Web Security Agent".
Status	Status of access agent: "Activated" or "Disabled".
Segment	Segment the access agent belongs to.

Detailed configuration differs depending on the access agent implementation type.

Application Security Agent / Physical Access Application

Attributes Tab
This tab contains the system-defined as well as custom (user-defined) attributes. • URL/Path to launch the application: The URL/path of UAM application. If specified, USO Agent will list UAM applications, on top of USO applications assigned to the user. • Allow Multiple Profiles: This allows the user to have multiple login profiles (secondary account) for the same application. Default: false • Allow Account Sharing: Account Sharing should not be allowed as the application may use reverse lookup feature (where given application login id, user identity would be lookup from the user repository) now or in future. Default: true
Resource Tab
This tab contains resource definition fields. Defines the resources to be accessible to the Application Security Agent / Physical Access Application.
Method Tab
This tab contains the method definition fields. Defines the methods to be used by Application Security Agent / Physical Access Application.
Role Tab
This tab contains role definition fields. All the application roles defined here are considered private to the application itself.
Permission Tab

Attributes Tab
Resource, Method, Application Role
- For each resource defined, the administrator is required to specify the desired method, and the desired application roles to be granted permission to perform the selected method in accessing the resource. - The application roles available for selection consist of private and dynamic application roles. If the resource is to be considered non-private, i.e. accessible by any user, the administrator should select the dynamic application role 'Everyone' for the particular resource. Note: For Physical Access Application type, an Open method will be pre-created and this method cannot be deleted.
Authentication Level, Login Module
- If applicable, the administrator may specify the desired authentication level or login module for the relevant resource. If the authentication level specified for the resource is higher than the authentication level of current login module used by the user when accessing the resource, the user will be requested to re-authenticate using the login module that has the same or higher authentication level. Failing to do so will deny the user from accessing the resource. - Meantime, if a particular login module is specified for the resource, the current login module used by the user must be the same as the one specified for the resource when accessing the resource, otherwise, the user will be denied access. - Thus, the administrator is advised not to specify any login module for the resource unless necessary. If so, the administrator must ensure that the authentication level of the login module specified should be either same as or higher than the authentication level specified for the resource. Otherwise, the login module specified does not serve any significant purpose. - To specify the desired authentication level, select from the drop-down list. - To specify the desired login module, click on relevant Modify button. Only login module with authentication level either same as or higher than the selected authentication level will be displayed on the list. Select by checking the desired login module and click OK.
Restriction
- If applicable, the administrator may specify the desired restrictions in terms of access location and access time, to be imposed onto the resource. - To specify the desired restriction, click on the relevant Modify button. Select the desired restriction and click OK.
Contextual Evaluation
- If applicable, the administrator may specify the desired contextual evaluation by defining the desired expression in terms of parameter name-value pairs, to be imposed onto the resource. - To specify the desired contextual evaluation expression, click on the relevant Modify button. Define the desired contextual evaluation and click OK.

Attributes Tab
Authorization Responses
- If applicable, the administrator may specify the desired authorization response for the resource. This is where the user response, discussed in User Response Configuration, is applied for the resource. - To specify the desired authorization response, click on the relevant Modify button. Select the desired authorization response and click OK.
Audit Flag
- If applicable, the administrator may specify the desired audit flag to be imposed onto the URL. "Always": means access to the resource will always be audited regardless of whether the user has been granted permission for the resource. "Never": means access to the resource will never be audited regardless of whether the user has been granted permission for the resource. "On Success": means access to the resource will only be audited if the user has been authenticated successfully and is authorized to access. "On Failure": This means access to the resource will only be audited if the user has failed to be authenticated or is not authorized to access. - To specify the desired audit flag, select from the drop-down list. After defining the desired permission rules and conditions for the particular resource, click Add to confirm to add the permission. - As a result, the user will only be granted permission to access the resource if all the rules or conditions specified for the particular resource are satisfied. Note: The administrator may remove the resource permission added by clicking on Delete for the associated resource permission.

Web Security Agent

	Note: ' * ' denotes mandatory attribute.
Attribute Name	Description
Attributes Tab	
*Web Server Type	The type of web server.
*Host	The web site full DNS name as entered by the user within the web browser, e.g. "www.i-sprint.com".
Port	The port of the web server Value should be from 1 to 65535 Default: 80

Attribute Name	Description
Context	The context directory where the application resides. This parameter is utilized when two different applications are accessing the same URL, therefore, specific information such as the base directory needs to be specified.
Cookie domain	The domain of the website to set the session cookie, e.g. ".i-sprint.com".
Secure Cookie	Whether to set the session cookie in a secure manner.
HTTP Only Cookie	Whether to set the session cookie only via HTTP.
Enforce Fixed User Agent	Whether to enforce a fixed user agent.
Enforce Fixed Remote IP Address	Whether to enforce a fixed remote IP address.
Login URL	The URL of the login page.
Login Succeeded URL	The URL to be redirected to, upon successful login.
Login Failed URL	The URL to be redirected to, upon login failure.
Logout Succeeded URL	The URL to be redirected to, upon successful logout.
Change Password URL	The URL of the change password page.
Change Password Succeeded URL	The URL to be redirected to, upon successful password change.
Access Denied URL	The URL to be redirected to, when access is denied.
Reauthenticate URL	The URL of the reauthenticate page.
Reauthentication Successful URL	The URL to be redirected to, upon successful reauthentication.
URL/Path to launch application	The URL/path of UAM application. If specified, USO Agent will list UAM applications, on top of USO applications assigned to the user.
Allow Multiple Profiles	This allows the user to have multiple login profiles (secondary account) for the same application. Default: false
Allow Account Sharing	Account Sharing should not be allowed as the application may use reverse lookup feature (where given application login id, user identity would be lookup from the user repository) now or in future. Default: true

Attribute Name	Description
URL Resource Tab	
This tab contains the URL patterns to be protected by WSA, e.g. <code>"/protected/*"</code>. Note: All undefined URLs will be treated as protected resources.	
Method Tab	
This tab contains the pre-defined methods, which are standard HTTP request methods supported by the web server, e.g. "GET", "POST".	
Role Tab	
This tab contains the application role definitions. Note: All application roles defined here are considered private to the application itself.	
Permission Tab	
URL Resource, Method, Application Role*	
- For each URL defined, the administrator is required to specify the desired method, and the desired application roles to be granted permission, to perform the selected method in accessing the URL. - The application roles available for selection consist of private and dynamic application roles. If the URL is to be considered non-private, i.e. accessible by any user, the administrator should select the dynamic application role 'Everyone' for the particular URL.	
Authentication Level, Login Module	
- If applicable, the administrator may specify the desired authentication level or login module for the relevant URL. If the authentication level specified for the URL is higher than the authentication level of current login module used by the user when accessing the URL, the user will be requested to re-authenticate using the login module that has the same or higher authentication level. Failing to do so will be denied the user from accessing the URL. - Meantime, if a particular login module is specified for the URL, the current login module used by the user must be the same as the one specified for the URL when accessing the URL, otherwise, the user will be denied access. - Thus, the administrator is advised not to specify any login module for the URL unless necessary. If so, the administrator must ensure that the authentication level of the login module specified should be either same as or higher than the authentication level specified for the URL. Otherwise, the login module specified does not serve any significant purpose. - To specify the desired authentication level, select from the drop-down list. - To specify the desired login module, click on the relevant Modify button. Only login module with authentication level either same as or higher than the selected authentication level will be displayed on the list. Select the desired login module and click OK.	
Restriction	

Attribute Name	Description
	- If applicable, the administrator may specify the desired restrictions in terms of access location and access time, to be imposed onto the URL. - To specify the desired restriction, click on the relevant Modify button. Select the desired restriction and click OK.
Contextual Evaluation	
	- If applicable, the administrator may specify the desired contextual evaluation by defining the desired expression in terms of parameter name-value pairs to be imposed onto the URL. - To specify the desired contextual evaluation expression, click on the relevant Modify button. Specify the expression that uses the parameter's name and value defined, and click OK after specifying the contextual evaluation expression.
Authorization Responses	
	- If applicable, the administrator may specify the desired authorization response for the URL. This is where the user response, discussed in User Response Configuration is applied for the URL. - To specify the desired authorization response, click on the relevant Modify button. Select the desired authorization response and click OK.
Audit Flag	
	- If applicable, the administrator may specify the desired audit flag, to be imposed onto the URL. "Always": means access to the URL will always be audited regardless of whether a user has been granted permission for the URL. "Never": means access to the URL will never be audited regardless of whether the user has been granted permission for the URL. "On Success": means access to the URL will only be audited if the user has been authenticated successfully and is authorized to access. "On Failure": means access to the URL will only be audited if the user has failed to be authenticated or is not authorized to access. - To specify the desired audit flag, select from the drop-down list. After defining the desired permission rules and conditions for the particular URL, click Add to confirm to add the permission. - As a result, the user will only be granted permission to access the URL if all the rules or conditions specified for the particular URL are satisfied. Note: The administrator may remove the URL permission added by clicking on Delete for the associated URL permission.

User Auto Provisioning Module Configuration

The administrator can configure the AccessMatrix system to allow the creation of a new user and automatically provisions the user's data to the default store or JDBC user store.

To locate the **User Auto Provisioning Module** page, navigate to **Administration Dashboard > Configuration > Authentication > User Auto Provisioning Module**. The following tasks can be performed on the **User Auto Provisioning Module** page:

- **Create** a user auto provisioning module - Click **Create** and select "Default User Auto Provisioning Handler" from the **Implementation** drop-down list, and then click **Next** to display the **Create User Auto Provisioning Module** page. Enter the details and save.
- **Search** an existing user auto provisioning module - The module can be searched by entering a user auto provisioning module Id or a user auto provisioning module name on the empty fields, and click **Search**. All available user auto provisioning modules are displayed by default on the **Search User Auto Provisioning Module Result** page.
- **View** an existing user auto provisioning module - Click a user auto provisioning module Id under the **Search User Auto Provisioning Module** page to view its details.
- **Edit** user auto provisioning module - Click **Edit** on the **View User Auto Provisioning Module** page to modify the details and save.
- **Delete** user auto provisioning module - Click **Delete** on the **View User Auto Provisioning Module** page and select **OK** on the Confirm dialog box.



Notes:

- The search can be based on a wildcard (*) or exact phrase match and it is case-sensitive. e.g. If "DEMO*" is entered for a search field, the entry with an Id of "DEMO123" will be retrieved, however, not "123DEMO". Enter "*DEMO" to retrieve "123DEMO", or leave the search field blank to search for all available results.
- The search criterion is also based on 'AND' condition. e.g. If the administrator enters values for both Id and Name fields, then only the results matching both values will be retrieved.

View User Auto Provisioning Module Page Attribute Description



Note: ' * ' denotes mandatory attribute.

Attribute Name	Description
*User Auto Provisioning Module Id	Unique Id of user auto provisioning module.
*User Auto Provisioning Module Name	Name of user auto provisioning module.
Description	Description of user auto provisioning module.
Version	User auto provisioning module entry version.
Implementation	Default user auto provisioning handler.
Configuration Tab	
*User Store	User store associated with the user auto provisioning module.
User Auto Provisioning Mapping	
This module is used to support auto-provisioning for the user from the external identity provider. This process requires attribute mapping to facilitate user creation in AccessMatrix repository based on the payload of the asserted user obtained from external Identity Provider.	
*Mapping User Id	Specify the payload's claim/attribute name of an entity (typically the user) to map its value to AccessMatrix User Id, or enter "userIdentity" that indicates the selected claim value of identity mapping for AccessMatrix UAM, the OIDC Relying Party.
*Mapping User Name	Specify the payload's claim/attribute name of an entity (typically the user) to map its value to AccessMatrix User Name, or enter "userIdentity" that indicates the selected claim value of identity mapping for AccessMatrix UAM, the OIDC Relying Party.
Mapping User Attributes	Specify the payload's claim/attribute name of an entity (typically the user) to map its value to AccessMatrix User Attributes, or enter "userIdentity" that indicates the selected claim value of identity mapping for AccessMatrix UAM, the OIDC Relying Party.
Auto User Provisioning Configuration	
This section allows newly created user to be automatically assigned with certain entitlements, such as having user assigned with "Default Authentication Realm" and/or auto-grouped under a Segment Id .	
Default Authentication Realm	Select an associated authentication realm to assign to users created by User Auto Provisioning Module.
Segment Id	Users that are created by the User Auto Provisioning Module will be assigned to this segment. The segment will be automatically created via

Attribute Name	Description
	segment mapping only, if it does not exist prior to the automatic provisioning. Segment mapping is supported by prefixing '@' to the attribute name. Note: Segment mapping will only create an immediate child segment that is assigned to the user, and does not create additional parent segments higher up on the hierarchy. To assign the child segment to a specific parent segment, ensure that the parent segments have been created before initiating this process.

Report

This section contains the UAM-related reports found under Report Dashboard. All reports can be generated into an HTML, PDF or CSV file.


Notes:

- While generating reports, leaving a field blank or entering a ' * ' wildcard will search for all available results.
- Attributes marked with ' * ' denote mandatory; a value must be entered to be able to generate the report.

Enterprised SSO & Web SSO Reports

Enterprised SSO & Web SSO Reports include the UAM application summary and web SSO privileges.

Real Time Reports

Real-time reports allow the administrator to perform live monitoring of the UAM authorization events. Below are the Web SSO-related real-time reports.

Application Summary By Segment Report

This report provides the summary of the number of Application Security Agent and Web Security Agent that belongs to a specific segment. In addition, the report can also be filtered by segment Id or by segment name.

To locate the **Application Summary By Segment Report** page, navigate to **Report Dashboard > Enterprised SSO & Web SSO > Real Time** and click **Application Summary By Segment** on the left

pane. Enter relevant search criteria to generate the report. Refer to [Enterprised SSO & Web SSO Report Sample](#). See below for the attributes description of the generated report:

Attribute Name	Description
Segment Id	Unique Id of the segment.
Segment Name	Name of the segment.
Hierarchical Path	Path of the parent segment.
Number of Application Security Agent	Number of Application Security Agents associated with the segment.
Number of Web Security Agent	Number of Web Security Agents associated with the segment.
Number of USO Applications	Number of USO Applications associated with the segment.
Total Applications	Total number of applications associated with the segment.

User Web SSO Privilege Report

This report provides the summary of the Web Single Sign-On (SSO) privilege of a user. In addition, the report can also be filtered by user store or by actor user Id.

To locate the **User Web SSO Privilege Report** page, navigate to **Report Dashboard > Enterprised SSO & Web SSO > Real Time** and click **User Web SSO Privilege** on the left pane. Enter relevant search criteria to generate the report. Refer to [User Web SSO Privilege Report Sample](#). See below for the attributes description of the generated report:

Attribute Name	Description
Access Agent Id	Unique Id of the access agent application associated with the user.
Role	The application role associated with the access agent.
Start Time	The time when the event occurred.
End Time	The time when the event ended.
Group Id	The group Id associated with the user.

Historical Reports

Historical reports allow the administrator to analyze the past system and user events. Below is the web SSO-related historical report.

Failed Web SSO Authorization By Application Resource Report

This report lists down all failed web SSO events based on the specified date/time.

To locate the **Failed Web SSO Authorization By Application Resource Report** page, navigate to **Report Dashboard > Enterprised SSO & Web SSO > Historical** and click **Failed Web SSO Authorization By Application Resource** on the left pane. Enter relevant search criteria to generate the report. Refer to [Failed Web SSO Authorization By Application Resource Report Sample](#). See below for the attributes description of the generated report:

Attribute Name	Description
Audit Id (Server Id)	Indicates the audit Id and server Id of the actor.
Actor User Id@User Store	Indicates the user Id and user store of the actor.
Reported Time	The time when the failed web SSO authorization occurred.
Actor IP Address	IP address of the actor.
Client Type	The client access type used for the event.
Client Id	Indicates the client Id/access agent Id of the application.
Method	Indicate the HTTP method used for the event.
Message	Contains the application, resource, method and reason of the failed Web SSO event.

4. AccessMatrix Single-Sign-On (SSO) Portal

AccessMatrix SSO Portal is a web portal that allows the end users to launch the UAM applications they are entitled to. This portal is not restricted to any web browser, and it can also be accessed using mobile devices.

To launch the UAM application using AccessMatrix SSO Portal, specify the AccessMatrix SSO Portal URL value: *http://<hostname>:<port>/usoserver/start.uso* (e.g. *http://localhost:8080/usoserver/start.uso*) in the **uso.url** attribute of "Application Security Agent"/"Physical Access Application". For WSA Application, specify the URL to URL/Path to launch application attribute.



Note: UAM application and AccessMatrix SSO Portal should be running on the same domain.

Refer to the [AccessMatrix SSO Portal Guide](#) for more information on how to launch and use this portal.

5. UAM Federated SSO

The following sections contain information on administration for various authentication protocols:

- [UAM Federated SSO via SAML](#)
- [UAM Federated SSO via OAuth 2.1 and OIDC](#)
- [UAM Federated SSO via JWT Authentication](#)

5.1. UAM Federated SSO via OAuth 2.1 and OIDC

In general, the OAuth 2.1 protocol controls authorization to access a protected resource, whereas the OpenID Connect protocol is built on the OAuth 2.1 protocol and helps authenticate users and convey information about them.

Currently, UAM plays the role of OAuth 2.1 Authorization Server and OpenID Connect Provider (OP), mainly for Single Sign-On purpose where it is:

- Capable of authenticating the end user (as part of AM5 authentication) and providing static Claims to a Relying Party about the Authentication event and the end user.
- Issuing access tokens to the client after successfully authenticating the end user and obtaining authorization.
- Expected that the customer builds the Authentication and Authorization UI/front end to display to the users and uses UAM to process the OAuth 2.1/OpenID Connect request and provides a response.

To use OAuth 2.1 or OpenID Connect for federated SSO, the administrator must configure the OAuth Authz Server and set up the OAuth client.

OAuth Authz Server

To locate the **OAuth Authz Server** page, navigate to **Administration Dashboard > Configuration > Unified SSO > Federated SSO > OAuth 2.0 & OpenID Connect > OAuth Authz Server**. The following tasks can be performed on the **OAuth Authz Server** page.

- **Edit** OAuth Authz Server - Click **Edit** on the **View OAuth Authz Server** page to modify the details and save.
 - **View** OpenID Connect JWK - Click **View OpenID Connect JWK** to display JSON Web Key(s) in JSON format.
 - **Generate** OpenID Connect Signing Key Pair - Click **Generate OpenID Connect Signing Key Pair** to generate a new key pair for the signing of OpenID Connect Id token. This button is also used to trigger key rotation.
 - **Export** OpenID Provider Metadata - Click **Export OpenID Provider Metadata** to export an OpenID Provider metadata for detailed information.
-

Attribute Name	Description	Mandatory (Y/N)
OAuth Authz Server Id	Unique Id of OAuth Authz Server.	Y
OAuth Authz Server Name	Name of OAuth Authz Server.	Y
Description	Description of OAuth Authz Server.	N
Version	OAuth Authz Server entry version.	Y
Issuer	OAuth Authz Server Issuer Id. This value is used to specify the issuer of JWT token (e.g. "ID Token").	Y
JWT/ID Token Tab		
Authorization Code Validity Time (in seconds)	This value is used by OAuth Authz Server to compute the expiry time of Authorization Code, it should be from 30 to 600. Default: 60	N
ID Token (JWT) Validity Time (in minutes)	This value is used by OAuth Authz Server to compute the expiry time of JWT token, it should be from 3 to 120. However, if the OAuth client is configured to embed the session token in the ID token, then the expiry will be based on the setting of Session Idle Time in Global Setting . Default: 60	N
Remove typ JWT Header claim of Access Token JWT	When enabled, this removes the "typ" claim in the JWT header of the access token if it is generated in the JWT format. Default: false	N
Key pair used for signing in ID Token (JWT)		
Key store	Keystore for signing an ID token. Key rotation using a keystore is not supported. Alternatively, use system generated a key pair for key rotation instead.	N
Key store passphrase	Passphrase of the keystore for signing ID token. If the private key does exist in the keystore, this passphrase should be used as the passphrase of the private key as well.	N
Key alias	Alias of the keystore used for signing ID token.	N
System generated key pair for signing in ID Token (JWT)		
RSA key length	RSA key length used to generate new RSA key pair for the signing of ID token. Default: 2048	N

Attribute Name	Description	Mandatory (Y/N)
Wrapping Key	Wrapping key is the symmetric key required to generate OpenID Connect signing key pair. This key is used to protect system-generated signing key pair.	N
No. of public keys to remember for verification	After key rotation, the older public key can still be retrieved for verification of ID token signature (It is possible since the ID tokens previously issued and signed with the older key pair could be still active and not yet expired). This value will determine the number of systems generated public keys that can be used for verification of ID token and it should not be less than 2. Default: 2	N
Scope Management		
Scopes	Authorization server supported scope(s). You may define the custom scope or use OIDC predefined scope (profile, email, address, phone). Each scope needs to be mapped with its corresponding User Response as Scope Value, its Consent Rule with either "REQUIRED" or "NOT_REQUIRED" to indicate whether the scope will require user consent, and needs to check the corresponding checkbox whether to return claims in ID token, user info, or access token (JWT/JWE).	N
User Consent		
CLP Consent Validity Period (in seconds)	CLP consent validity period is used to compute the acceptable interval in time during which user consent can or must take place. Consent request created time - half window of the validity period < consented time < consent request created time + half window of the validity period e.g. CLP Consent validity period is 3600 sec and consent request created time is 10:30am 10:27am < time during which user consent can or must take place < 10:33am Default: 360 seconds	N
OpenID Connect Discovery		
Endpoints		
Authorization endpoint	URL of the authorization server's authorization endpoint: $\{yourOAuthProxyURL\}/auth$ (For example, for CLP/OAuthProxy: <CLP/OAuthProxy URL>/auth)	N

Attribute Name	Description	Mandatory (Y/N)
Token endpoint	URL of the authorization server's token endpoint: \${yourOAuthProxyURL}/token (For example, for CLP/OAuthProxy: <CLP/OAuthProxy URL>/token)	N
User info endpoint	URL of the authorization server's user info endpoint: \${yourOAuthProxyURL}/userinfo (For example, for CLP/OAuthProxy: <CLP/OAuthProxy URL>/userinfo)	N
Jwks URI	URL of the authorization server's JSON Web Keys (in JSON format) endpoint: \${yourOAuthProxyURL}/jwks.json (For example, for CLP/OAuthProxy: <CLP/OAuthProxy URL>/jwks.json)	N
Revocation endpoint	URL of the authorization server's revocation endpoint: \${yourOAuthProxyURL}/revoke (For example, for CLP/OAuthProxy: <CLP/OAuthProxy URL>/revoke)	N
Introspection endpoint	URL of the authorization server's introspection endpoint: \${yourOAuthProxyURL}/introspect (For example, for CLP/OAuthProxy: <CLP/OAuthProxy URL>/introspect)	N

OAuth Client

To locate the **OAuth Authz Client** page, navigate to **Administration Dashboard > Configuration > Unified SSO > Federated SSO > OAuth 2.0 & OpenID Connect > OAuth Client**. The following tasks can be performed on the **OAuth Client** page.

- **Create** OAuth client - Click **Create** to launch the **OAuth Client Configuration Wizard**.



Note: For more information on configuring the OAuth client, refer to [UAM OAuth and OIDC OpenID Provider Implementation Guide - Admin Console Client Registration](#).

- **Search** for an existing OAuth client - OAuth client can be searched by entering an OAuth client Id and/or an client name on its respective empty fields, and then click **Search**. The OAuth client that is found will be displayed on the **Search OAuth Client Result** page.
- **View** an existing OAuth client - Click an OAuth client Id under the **Search OAuth Client Result** page to view its details.
- **Edit** OAuth client - Click **Edit** on the **View OAuth Client** page to modify the details and save.
- **Delete** OAuth client - Click **Delete** on the **View OAuth Client** page and click **OK** on the **Confirm** dialog box.

-
- **View** OAuth client Secret - Click **OAuth Client Secret** on the **View OAuth Client** page to view the client secret of this OAuth client. Under specific grants (Authorization Code grant, Resource Owner Password Credential grant or Refresh Token), if the Token endpoint authentication method is set to "ClientSecret", then this value will be used by OAuth client application to authenticate with OAuth Authz Server during access token request.

For details on the configurable attributes for each OAuth client type, refer to [UAM OAuth and OIDC OpenID Provider Implementation Guide - Admin Console Client Registration](#).

5.2. UAM Federated SSO via SAML

SAML 2.0 is a protocol that you can use to perform federated single sign-on from Identity Providers to Service Providers. In federated single sign-on, users authenticate at identity provider. Service providers consume the identity information asserted by identity providers.

To use SAML 2.0 for federated SSO, the administrator must configure the Identity Provider, Service Provider and set up the SAML Configuration.

Identity Provider

To locate the **Identity Provider** page, navigate to **Administration Dashboard > Configuration > Unified SSO > Federated SSO > SAML > Identity Provider**. Following tasks can be performed on this page:

- **Create** Identity Provider - Click the **Create** button and select an implementation from the **Implementation** drop-down list to display the **Create Identity Provider** page, enter details and save.
- **Search** an existing Identity Provider - Can be searched by Identity Provider Id and/or Identity Provider Name. All available Identity Providers are displayed by default. A default Identity Provider "DefaultIdentityProvider" is pre-created.
- **View** an existing Identity Provider - Click on an Identity Provider Id under the **Search Identity Provider Result** to view its details.

i **Note:** The **Export Metadata** button exports the metadata into an XML file for loading to Service Provider.
Default filename: **i-sprint.com-metadata.xml**

- **Edit** Identity Provider - Click **Edit** on the **View Identity Provider** page to modify the details and save.

i **Note:** The **Import Metadata** button imports the metadata files for Identity Provider. Click the **Browse...** button to locate the file and click the **Upload Metadata** button to upload the file.

- **Delete** Identity Provider - Click **Delete** on the **View Identity Provider** page and select **OK** in the confirmation pop-up box.

i **Notes:**

- The search can be based on a wildcard (*) or exact phrase match, and is case-sensitive. e.g. If "DEMO*" is entered for a search field, the entry with an Id of "DEMO123" will be

retrieved, however, not "123DEMO". Enter "*DEMO" to retrieve "123DEMO", or leave the search field blank to search for all available results.

- The search criterion is also based on 'AND' condition.
e.g. If the Administrator enters values for both the **Id** and **Name** fields, then only the results matching both values will be retrieved.

Identity Provider (UAM as Identity Provider) Page Attribute Description

Note: ' * ' denotes a mandatory attribute.

Attribute Name	Description
*Identity Provider Id	Unique Id of Identity Provider, e.g. "MyIdP".
*Identity Provider Name	Name of Identity Provider, e.g. "Identity Provider".
Description	Description of Identity Provider.
*Id used as issuer	A kind of Id, normally in the URL form to represent the Identity Provider entity.
General Tab	
Authentication Request	
Allowed Signature Algorithm	Allowed signature hash algorithms for validating signed request/artifact-resolve. Note: This attribute is only used by the AccessMatrix server that acts as an Identity Provider. Options: • "SHA1" • "SHA256" • "SHA384" • "SHA512" Default: SHA256, SHA384, SHA512
Authentication Response	
Assertion validity time (in seconds)	The validity of SAML Response and SAML Response's Assertion is based on a time-based condition which specifies the validity time range. When AccessMatrix UAM system is IdP, upon generating the SAML Response, this attribute value would be used to derive 'notOnOrAfter' time condition of the Assertion Subject and the Response Subject. Time is always in UTC timezone. The time unit of this attribute is in seconds. Default: 60
Assertion Start Time Validity Adjustment	For Identity Provider-initiated Response, when SAML Response is generated, its Assertion Subject's 'NotBefore' time is generated based on the issue time

Attribute Name	Description
(for IDP initiated response only)	of the Response. Sometimes the SP server time and Identity Provider server time may not be in sync and this will fail SP to use the SAML Response. To resolve this issue, this configuration is introduced to allow buffer time to be included (Assertion Subject's 'NotBefore' time = 'issueTime' - Assertion Start Time Validity Adjustment (for Identity Provider-initiated response only)) to Assertion Subject's 'NotBefore' time. Time is always in UTC timezone. The time unit of this attribute is in seconds. Default: 60
Web Browser SSO Tab	
Service URLs	
*Single Sign-On Service URLs	The Identity Provider service URL to receive the Authentication request or Single Sign-On request from the Service Provider. This value is used to specify the destination of the SAML Request. URL format: <HTTP Binding> - <SSO URL> - The URL with no binding is taken as a wildcard during API call, i.e. it can be taken as both HTTP-POST/Redirect. This URL with no binding will be exported as HTTP-POST binding during metadata export. - For the new entry URL that is both POST & Redirect, add two entries of different bindings using the same URL. Example: <POST> - <URL1> <Redirect> - <URL1>
Authentication Request	
Acceptance time (in seconds)	This setting is to control the validity of an authentication request; the difference between the time the authentication request is issued and the time the authentication request is received must be within this configured time. Default: 360
Authentication Request Required Signing	Enable this setting if SAML Request requires signing. Default: false
Artifact Resolution Tab	
Artifact Resolve Service URLs	The Identity Provider service URL(s) to receive the Artifact Resolve request from the Service Provider.
Digital Signature Tab	
Keystore	The path to the signing keystore file. The key pair(s) in the keystore is/are used for signing the SAML Response generated by the Identity Provider.

Attribute Name	Description
Keystore Passphrase	The password of the keystore.
Active Key Alias	The active key for signing.
Active Key Certificate's Expiry Date	The expiry date of the active key certificate.
Signature Algorithm	The signing algorithm used for SAML signature. Default: RSA_SHA256.
Log Expired Certificate	If enabled, an error log is added when an expired certificate from the keystore is used. This has no impact on the usage of the certificate, as the operation is still allowed to proceed even if the certificate has expired. Default: false
Key Rollover	
New Key Aliases	List of key aliases to use for key rollover. Aliases are used in order from the top of the list to the bottom for key rollovers. Usage of aliases restarts from the top of the list once again after reaching the bottom of the list. If there is currently no existing value configured for the Active Key Alias attribute, the first alias in the list is used.
Coexisting Key Alias	The new key to be rolled over to in the key rollover event. The value of Active Key Alias will be updated with this after the rollover event.
Enable Coexisting Key	When enabled, the coexisting public key string will be included in the exported metadata. The coexisting public key string will be identified as the "New Key" and the active public key string will be identified as the "Active Key". Default: false
Date to Perform Key Rollover	Date to start the signing key rollover process. Upon reaching the specified date, the value of Coexisting Key Alias is updated to the next unused alias in the New Key Aliases list. The use of the coexisting key is enabled. Both the coexisting key and active key public key string are included in the exported metadata. Note: The Start Key Rollover button must be clicked for the above to take effect.
Start Date of Coexisting Key Usage	Date to complete the signing key rollover process. Upon reaching the specified date, the value of Active Key Alias is updated to that of Coexisting Key Alias . Enable Coexisting Key is set to "false" and only the updated active key is used for signing. Only the active key public key string will be in the exported metadata.

Attribute Name	Description
	Note: The Complete Key Rollover button must be clicked for the above to take effect.

Identity Provider (UAM as Service Provider) Page Attribute Description

 Note: ' * ' denotes mandatory attribute.	
Attribute Name	Description
*Identity Provider Id	Unique Id of Identity Provider, e.g. "MyIdP".
*Identity Provider Name	Name of Identity Provider, e.g. "Identity Provider".
Description	Description of Identity Provider.
*Id used as issuer	A kind of Id, normally in the URL form to represent the Identity Provider entity.
General Tab	
Digital Signature	
Keystore	The path to the signing keystore file. The key pair(s) in the keystore is/are used for signing the SAML Response generated by the Identity Provider.
Keystore Passphrase	The password of the keystore.
Key Alias	The active key for signing.
Signature Algorithm	Default: RSA_SHA256
IdP public key string	It is used to verify response signature (sent by Identity Provider). Note: Referred by Service Provider when AM5 serves as Service Provider.
Web Browser SSO Tab	
Service URLs	
*Single Sign-On Service URLs	The Identity Provider service URL to receive the Authentication request or Single Sign-On request from the Service Provider. This value is used to specify the destination of the SAML Request. URL format: <HTTP Binding> - <SSO URL>

Attribute Name	Description
	- The URL with no binding is taken as a wildcard during API call, i.e. it can be taken as both HTTP-POST/Redirect. This URL with no binding will be exported as HTTP-POST binding during metadata export. - For the new entry URL that is both POST & Redirect, add two entries of different bindings using the same URL. Example: <POST> - <URL1> <Redirect> - <URL1>
Authentication Request	
Authentication Request Required Signing	Enable this setting if SAML Request requires signing. Default: false
Artifact Resolution Tab	
Service URLs	
Artifact Resolve Service URLs	The Identity Provider service URL to receive Artifact Resolve request from Service Provider.
HTTP Proxy	
Enabled	Set this attribute to "true" to enable Http Proxy. Note: Only applicable to Artifact Resolve Service URLs. Default: false
URL	Refers to the proxy URL.
Port	Refers to the proxy port.
User Name	Refers to the proxy username.
User Password	Refers to the proxy password.
NTLM Authentication	If NTLM Authentication is enabled, Domain name must be specified. In addition to that, it may be needed to configure the AccessMatrix server host domain name or IP address in amsystem.properties with property key "am.saml.ntlm.host" for each instance. Default: false
Domain Name	The domain name value used when NTLM Authentication is enabled.

Signing Certificate or Public Key

- Used for signing authentication response or assertion.
- Public key is required to verify a signature, it is to be placed in a key store.
- When AccessMatrix UAM system is Service Provider, the public key for verifying the certificate should be in the key store of the AccessMatrix UAM system Identity Provider configuration.



Notes:

- Alternatively, signing key can be configured in "IdP public key string".
- The SAML scope used for signing response by default is "Response". AccessMatrix UAM also supports signing "Assertion". To find out more, view **Response signature scope** under **General** tab of the [Service Provider](#) section.
- Learn more about SAML Web SSO configuration and key rollovers by referring to [SAML Web SSO Configuration](#).

Service Provider

To locate the **Service Provider** page, navigate to **Administration Dashboard > Configuration > Unified SSO > Federated SSO > SAML > Service Provider**. The following tasks can be performed on the **Service Provider** page:

- **Create** Service Provider - Click the **Create** button and select an implementation from the **Implementation** drop-down list to display the **Create Service Provider** page, enter details and save.
- **Search** an existing Service Provider - Can be searched by Service Provider Id and/or Service Provider Name. All available Service Providers are displayed by default.
- **View** an existing Service Provider - Click on a Service Provider Id under the **Search Service Provider Result** to view its details.



Note: The **Export Metadata** button exports the metadata into an XML file for loading to Identity Provider.
Default filename: **sdf-metadata.xml**

- **Edit** Service Provider - Click **Edit** on the **View Service Provider** page to modify the details and save.



Note: The **Import Metadata** button imports the metadata files for SP. Click the **Browse...** button to locate the file and click the **Upload Metadata** button to upload the file.

- **Delete** Service Provider - Click **Delete** on the **View Service Provider** page and select **OK** in the confirmation pop-up box.
-

**Notes:**

- The search can be based on a wildcard (*) or exact phrase match and is case-sensitive. e.g. If "DEMO*" is entered for a search field, the entry with an Id of "DEMO123" will be retrieved, however, not "123DEMO". Enter "*DEMO" to retrieve "123DEMO", or leave the search field blank to search for all available results.
- The search criterion is also based on 'AND' condition. e.g. If the Administrator enters values for both the **Id** and **Name** fields, then only the results matching both values will be retrieved.

Service Provider (UAM as Identity Provider) Page Attribute Description**Note:** ' * ' denotes a mandatory attribute.

Attribute Name	Description
*Service Provider Id	Unique Id of Service Provider, e.g. "MySP".
*Service Provider Name	Name of Service Provider, e.g. "Service Provider".
Description	Description of Service Provider.
*Id used as issuer	A kind of Id, normally in the URL form to represent the Service Provider entity.
General Tab	
Assertion	
*Assertion Consumer Service URLs	SP's URL to consume SAML assertion. This configuration is needed when the AccessMatrix UAM system is an identity provider or a service provider, to specify the recipient of the SAML Response.
Name Id	
Note: Either Value or both Value and User Response to return as a name Id value attributes have to be mandatory.	
Format	A constant to describe the Name ID value and it is used to export SP metadata. The important thing is to agree on the Name ID format between IdP and SP. Possible values: • "Email" (urn:oasis:names:tc:SAML:1.1:nameid-format:emailAddress) • "Persistent" (urn:oasis:names:tc:SAML:2.0:nameid-format:persistent) • "Unspecified" (urn:oasis:names:tc:SAML:1.1:nameid-format:unspecified) • "Transient" (urn:oasis:names:tc:SAML:2.0:nameid-format:transient) Default: Unspecified

Attribute Name	Description
Value	The value to be retrieved from the user object as user identity. If a user's identity is to be retrieved from User Response (e.g. user's UUID), configure this attribute to "User Response" instead. Possible values: • "Id" • "Name" • "DN" • "Email" • "Secondary Account" • "User Response"
User Response to return as NameID value	The value to be retrieved from the User Response as user identity. This setting is used when Name ID Value is set as "User Response". User Response configuration can be chosen as flexibility in specifying what value to return as Name ID value. Specify only one field/attribute in the User Response configuration. If it contains more than one value, only one (randomly chosen) will be used.
Attributes	
Attributes to return in the assertion	Upon successful authentication, the specified set of user information to be sent to this service provider as part of the assertion. User Response configuration is used to specify this information. Note: SAML Assertion allows add-on payload to include user attributes or other information from the identity provider to service provider.
Response	
Response signature scope	It is used to define the scope of the SAML Response to be signed, e.g. Response, Assertion, etc. Possible values: • "Response" • "Assertion" Default: Response
Assertion Encryption	Indicate whether to apply encryption to SAML Response's assertion. Note: This attribute is only used by the AccessMatrix server that acts as an Identity Provider. Default: false
Access Control	
Allow All Users to Access	Enabling this feature will allow all authenticated users to access this Service Provider. To control user access to the web applications or web services of a Service Provider, this setting must be disabled. To control user access, go to the SAML Application Privilege tab of the View User page and define which

Attribute Name	Description
	service provider is accessible for that particular user. Default: true
Others	
Response Authentication Context Mapping	This feature is used to enable the use of authentication context processing. Specify an authentication context here to require the user to be authenticated using that authentication context for IdP-initiated SAML use cases. Multiple contexts can be specified. The specified context(s) will serve as the requested authentication context(s) and be used in the validation of the SAML response; authentication will fail if the expected authentication context(s) is/are not found.
Allow Multiple Profiles	This is to allow a user to have multiple login profiles (a secondary account) for the same application. Note: This attribute is only used by the AccessMatrix server that acts as an Identity Provider. Default: false
Is WSA Being Used?	A flag to indicate if WSA is being used. Default: false
Web Browser SSO Tab	
URL to initiate SSO	A URL that initiates SAML SSO operation. It is a URL to the servlet(s) for the SSO service or the SAML Authentication Request Service. Note: It is required only by Identity Provider portal or USO Agent.
Is IDP Initiated Flow	If set to "true", AccessMatrix allows multiple SAML SP configurations to be editable or created with the same SP Issuer ID. Default: false
Digital Signature Tab	
Note: Only specify the public key for signature verification of the authentication request.	
Keystore	The path to the signature keystore file. The key pair(s) in the keystore is/are for signature verification of the SAML Request received from the Service Provider.
Keystore Passphrase	The password of the keystore.
Active Key Alias	The active key for signature verification.
Active Key Certificate's Expiry Date	The expiry date of the active key certificate.

Attribute Name	Description
Log Expired Certificate	If enabled, an error log is added when an expired certificate from the keystore is used. This has no impact on the usage of the certificate, as the operation is still allowed to proceed even if the certificate has expired. Default: false
Key Rollover	
New Key Aliases	The list of key aliases for key rollover. Aliases are used in order from the top to the bottom of the list for key rollover. The current active alias must be before the alias that will be rolled over to in the list. If there is currently no existing value configured for the Active Key Alias , the first alias in the New Key Aliases list is used. Usage of aliases restarts from the top of the list once again after reaching the bottom of the list.
Coexisting Key Alias	The old key to be rolled over from in the key rollover event. The value of Active Key Alias before the rollover will be updated to this in the rollover event.
Enable Coexisting Key	When enabled, both the active key and coexisting key are used for signature verification.
Start Date of Coexisting Key Usage	Date to start the verification key rollover process. Upon reaching the specified date, the value of the Coexisting Key Alias attribute is updated to that of the Active Key Alias attribute. The use of the coexisting key is then enabled. The value of the Active Key Alias attribute is updated to the next alias in the New Key Aliases list. If signature verification using the updated active key public key fails, the coexisting key public key is used instead. Note: The Start Verification Key Rollover button must be clicked for the above to take effect.
Stop Date of Coexisting Key Usage	Date to complete the verification key rollover process. Upon reaching the specified date, the use of the coexisting key is disabled. Enable Coexisting Key is set to "false" and the system stops the use of the old key; only the active key public key will be used for signature verification. Note: The Complete Verification Key Rollover button must be clicked for the above to take effect.
XML Encryption Tab	
Note: Only specify the public key for encryption of the authentication response/assertion.	
Keystore	Path to the encryption keystore file. The key pair(s) in the keystore is/are for encrypting the assertion of the SAML Response generated by the Identity Provider.
Keystore Passphrase	The password of the keystore.

Attribute Name	Description
Active Key Alias	The active key for encryption.
Encryption Algorithm	The algorithm used for the SAML Response's assertion encryption. Options: "AES128" "AES256" Default: AES_128
Log Expired Certificate	If enabled, an error log is added when an expired certificate from the keystore is used. This has no impact on the usage of the certificate, as the operation is still allowed to proceed even if the certificate has expired. Default: false
Key Rollover	
New Key Aliases	The list of key aliases for key rollover. Aliases are used in order from the top to the bottom of the list for key rollover. The current active alias must be before the alias that will be rolled over to in the list. If there is currently no existing value configured for the Active Key Alias, the first alias in the New Key Aliases list is used. Usage of aliases restarts from the top of the list once again after reaching the bottom of the list.
Active Key Certificate's Expiry Date	The expiry date of the active key certificate.
Date to Perform Key Rollover	Date to perform the encryption key rollover process. The value of Active Key Alias is updated to the next key in the New Key Aliases list. The updated active key is used for encryption. Note: The Start Encryption Key Rollover button must be clicked for the above to take effect.

Service Provider (UAM as Service Provider) Page Attribute Description

 Note: ' * ' denotes a mandatory attribute.	
Attribute Name	Description
*Service Provider Id	Unique Id of Service Provider, e.g. "MySP".

Attribute Name	Description
*Service Provider Name	Name of Service Provider, e.g. "Service Provider".
Description	Description of Service Provider.
*Id used as issuer	A kind of Id, normally in the URL form to represent the Service Provider entity.
Web Browser SSO Tab	
URL to initiate SSO	Note: It is required only by IdP portal or USO Agent.
General Tab	
Response	
Response signature scope	It is used to define the scope of the SAML Response to be signed, e.g. Response, Assertion, etc. Possible values: "Response" "Assertion" Default: Response
Allowed Signature Algorithm	Allowed signature hash algorithms for validating signed response/assertion/artifact-response. Options: "SHA1" "SHA256" "SHA384" "SHA512" Default: SHA256, SHA384, SHA512
Assertion Encryption	Referred for Metadata export.
Assertion	
*Assertion Consumer Service URLs	SP's URL to consume SAML assertion. This configuration is needed when the AccessMatrix UAM system is an identity provider or a service provider, to specify the recipient of the SAML Response.
Assertion Acceptance time (in seconds)	The difference between the time the assertion is issued and the time the assertion is received must be within this configured time. Default: 240
Assertion Condition Tolerance time (in seconds)	This feature mitigates IdP/ SP server time out of sync issues during assertion validation by computing a time window that allows for greater tolerance.

Attribute Name	Description
	Note: The time window is a range that is derived between subtracting this attribute from "Assertion Condition Not On datetime", and by adding this attribute to "Assertion Condition After datetime".
Name Id	
Format	A constant to describe the Name ID value and it is used to export SP metadata. The important thing is to agree on the Name ID format between IdP and SP. Possible values: "Email" (urn:oasis:names:tc:SAML:1.1:nameid-format:emailAddress) "Persistent" (urn:oasis:names:tc:SAML:2.0:nameid-format:persistent) "Transient" (urn:oasis:names:tc:SAML:2.0:nameid-format:transient) "Unspecified" (urn:oasis:names:tc:SAML:1.1:nameid-format:unspecified) Default: Unspecified
Assertion Attribute	
Assertion Attribute Unique Name	Name of SAML Assertion Attribute to use to uniquely identify the SAML attribute. Options: "Name" "FriendlyName" Default: Name
Digital Signature	
Keystore	The path to the signature keystore file. The key pair(s) in the keystore is/are for signature verification of the SAML Request received from the Service Provider.
Keystore Passphrase	The password of the keystore.
Key Alias	The active key for signature verification.
Signature Algorithm	Signing algorithm used for SAML Request. Options: "RSA_SHA1"

Attribute Name	Description
	"RSA_SHA256" Default: RSA_SHA256 Note: This attribute is only used by the AccessMatrix server that acts as a Service Provider.
XML Encryption	
Keystore	Path to the encryption keystore file. The key pair(s) in the keystore is/are for encrypting the assertion of the SAML Response generated by the Identity Provider.
Keystore Passphrase	The password of the keystore.
Key Alias	The active key for encryption.
Encryption Algorithm	Default: AES_128
Others	
Response Authentication Context Mapping	This feature is used to enable the use of authentication context processing. Specify an authentication context here to require the user to be authenticated using that authentication context for IdP-initiated SAML use cases. Multiple contexts can be specified. The specified context(s) will serve as the requested authentication context(s) and be used in the validation of the SAML response; authentication will fail if the expected authentication context(s) is/are not found.
SP Public Key String	If Digital Signature - Keystore or XML Encryption - Keystore is specified, the public key in that keystore will be used instead.
Allow Multiple Profiles	This is to allow a user to have multiple login profiles (a secondary account) for the same application. Default: false Note: This attribute is only used by the AccessMatrix server that acts as an Identity Provider.
Is WSA Being Used?	A flag to indicate if WSA is being used. Default: false
Artifact Resolution Tab	
SSL Client Authentication	
SSL Client Authentication for SAML SOAP Binding. It could be used for Artifact Resolution Protocol and Attribute Query Protocol.	

Attribute Name	Description
Keystore	Keystore for SSL Client authentication for SAML SOAP Binding.
Keystore Passphrase	The password of the keystore.
Key Alias	Identification of key store.

XML Encryption Keystore

To configure keypair used for XML encryption:

- **AccessMatrix UAM system as Identity Provider:**
 - Public key used by Identity Provider to encrypt SAML Response's assertion.
 - Import public key of Service Provider to the keystore of XML encryption.
- **AccessMatrix UAM system as Service Provider:**
 - Private key used by Service Provider to decrypt SAML Response's assertion.
 - Import private key of Service Provider to the keystore to do XML decryption.

SAML Configuration

To navigate to the **SAML Configuration** page, select **Administration Dashboard > Configuration > Unified SSO > Federated SSO > SAML > SAML Configuration**. The **SAML Configuration Page** can be edited by clicking **Edit** on the **View Configuration** page on the right pane.

SAML Configuration Page Attribute Description

	Note: ' * ' denotes mandatory attribute.
Attribute	Description
*Configuration Id	Unique Id of SAML configuration.
*Configuration Name	Name of SAML configuration.
Description	Description of configuration.
Version	Entry version of configuration.
Implementation	Type of configuration implemented, i.e. "SAML Configuration".

Attribute	Description
Attributes Tab	
*Default Identity Provider	To denote the default Identity Provider referenced by REST API call where Identity Provider (IDPId) is not specified.
Cache	
Response Lifetime	Lifetime of used response. This cache is to prevent reuse of response when the AccessMatrix UAM acts as a service provider. Value should not be less than 450. Default: 900
Response Cache Size	The number of used responses to be kept in cache. This cache is to prevent reuse of response when the AccessMatrix UAM acts as a service provider. Value should not be less than 5000. Default: 5000
Artifact Lifetime	Lifetime of artifact. The cache is used when the AccessMatrix UAM acts as an identity provider to cache user identity together with the artifact. Value should not be less than 120. Default: 300
Artifact Cache Size	The number of artifact to be kept in cache. The cache is used the AccessMatrix UAM acts as an identity provider to cache user identity together with the artifact. Value should not be less than 5000. Default: 5000

5.3. UAM Federated SSO via JWT Authentication

JSON Web Token (JWT) is a JSON encoded representation of claims that can be securely transferred between two parties. The claims are digitally signed by the issuer of the token. In this case, UAM, a JWT Provider, will sign it using its private key. The target application, a JWT Client, consumes the JWT after validating the signature using UAM's public key. In UAM JWT Authentication, the JWT contains the user's identity and optionally user attributes as well, such as email. As the application is able to validate the JWT without having to call UAM API, this feature is suitable to be used in distributed architecture or in federated SSO use case.

UAM issues JWT when authentication API is called with indication that JWT feature is required; this is done by specifying the `jwtClientId` parameter. The configurations in this section are used to specify which claims is included in the JWT, how JWT is signed, which application (JWT Client) is the intended audience, the validity of JWT, and among other things.

UAM also has the ability to issue JWT with user's session token embedded. This is useful when the backends of the application need the user's session token to call AccessMatrix APIs.

To use JWT Authentication for federated SSO, the administrator must configure the JWT Provider and set up the JWT Client.

JWT Provider

To locate the **JWT Provider** page, navigate to **Administration Dashboard > Configuration > Unified SSO > Federated SSO > JWT Authentication > JWT Provider**. The following tasks can be performed on the **JWT Provider** page.

- **Edit** JWT Provider - Click **Edit** on the **View JWT Provider** page to modify the details and save.
- **View** JWK - Click **View JWK** to display JSON Web Key(s) in JSON format.

 **Note:** Ensure that the signing keys are already generated before clicking this button.

- **Generate** JWT signing key pair - Click **Generate JWT Signing Key Pair** to generate a new key pair for signing of JWT. This button is also used to trigger key rotation.

 **Note:** A Wrapping Key must be provided to successfully generate signing keys.

JWT Provider Page Attribute Description

i Note: ' * ' denotes a mandatory attribute.

Attribute Name	Description
*JWT Provider Id	Unique Id of JWT Provider.
*JWT Provider Name	Name of JWT Provider.
Description	Description of JWT Provider.
Version	JWT Provider entry version.
*JWT Provider Issuer	A kind of Id, normally in the URL form to represent the JWT Provider entity, e.g. "i-sprint.com".
JWT Tab	
System generated key pair for signing JWT	
RSA key length	RSA key length used to generate new RSA key pair for the signing of JWT. Possible values: "2048" "4096" Default: 2048
Wrapping Key	Wrapping key is required to generate JWT signing key pair. This is used to protect system generated signing key pair for JWT. Refer to AccessMatrix Common Administration Guide - Configure Encryption Key to know about the creation of wrapping key.
No. of public keys to remember for verification	After key rotation, the older public key can still be retrieved for verification of JWT signature it is possible since the JWT previously issued and signed with the older key pair could be still active and not yet expired). This value will determine the number of systems generated public keys that can be used for verification of JWT. Value should be from 2 to 5. Default: 2
JWT validity time (in minutes)	This attribute specifies the validity of JWT (in minutes). This option is applicable only if Embed Session Token of the corresponding JWT Client is set to "false". When Embed Session Token is set to "true", then the Session Idle Time defined in the realm-based session policy of the authentication realm or in global setting will be used as the JWT validity time. Value should be from 1 to 120. Default: 10

JWT Client

To navigate to the **JWT Client** page, select **Administration Dashboard > Configuration > Unified SSO > Federated SSO > JWT Authentication > JWT Client**. The following tasks can be performed on the **JWT Client** page.

- **Create** a JWT client - Click **Create** to launch the **Create JWT Client** page.
- **Search** an existing JWT client - Existing JWT client can be searched by entering a JWT client Id and/or a JWT client name on its respective empty fields, and then click **Search** to display the search result. All available JWT clients are displayed by default on the **Search JWT Client Result** page.
- **View** an existing JWT client - Click a JWT client Id under the **Search JWT Client Result** page to view its details.
- **Edit** JWT client - Click **Edit** on the **View JWT Client** page to modify the details and save.
- **Delete** a JWT client - Click **Delete** on the **View JWT Client** page and click **OK** on the **Confirm** dialog box.

JWT Client Page Attribute Description

i Note: ' * ' denotes a mandatory attribute.	
Attribute Name	Description
*JWT Client Id	Unique Id of JWT client.
*JWT Client Name	Name of JWT client.
Description	Description of JWT client.
Version	JWT client entry version.
Attributes Tab	
Client Authentication	
Agent-based Access Restriction	This is to restrict which application (non-interactive user/agent) may use this JWT client to generate JWT upon authentication.
These are the Authentication Realms allowed to generate JWT	

Attribute Name	Description
Authentication Realm	Specifies the authentication realms that are allowed to generate JWT. The administrator can specify up to five (5) authentication realms and at least one authentication realm should be assigned. Note: The login user should be assigned to any of these authentication realms to successfully generate JWT.
JWT Claims	
*Value to return as Subject (sub) value	Value to return as a subject value in user's claim.
User Response to return as Subject (sub) value	This setting is used to determine the value used to compute subject of JWT when Value to return as Subject (sub) value is set to "User Response". If it contains more than one value, only one (randomly chosen) will be used.
Attribute claim value Response configuration	This attribute value has to be a User Response object to include additional claims of the user in JWT without user consent.
Embed Session Token	This option adds the user's AM5 session token as part of the JWT claim. This allows JWT to be used in the API when a "sessionToken" parameter is required. As the JWT contains the session token, this should be enabled only if the JWT client is trusted. If the JWT client does not need the user's AM5 session token, it is highly recommended to set this option to "false" (i.e. disable embedding of session token) for better security. When this option is enabled, the validity time of the JWT will follow the Session Idle Time defined in the realm-based session policy of the authentication realm or in global setting. Default: true
JWT Format	
JWT Format	Specifies the format of the JWT token. Options: "JWT" "JWE" If JWT Format is set to "JWE": - Ensure that the JWE Algorithm and JWE Encryption Algorithm attributes are configured. - Either the JWKS Endpoint URL or JWKS String attribute value is specified. Default: JWT
JSON Web Encryption (JWE)	
JWKS Endpoint URL	URL of the Relying Party's JWKS (JSON Web Key Set) endpoint.

Attribute Name	Description
JWKS String	A JSON object that represents a set of JWKS (JSON Web Key Set) published by the Relying Party. JWKS String takes precedence over JWKS Endpoint URL if both are specified.
JWE Algorithm	Cryptographic algorithm used to encrypt or determine the value of the CEK (Content Encryption Key). Required for JWE (JSON Web Encryption). Options: • "ECDH-ES+A256KW" • "RSA-OAEP-256"
JWE Encryption Algorithm	Content encryption algorithm used to perform authenticated encryption. Required for JWE (JSON Web Encryption). Options: • "A256CBC-HS512" • "A256GCM"

6. Cache Provider

AccessMatrix UAM requires to store some short-term data as part of Federated SSO. This is for the purpose to prevent replay attack, request forgery, and among other things. For example, for UAM as OIDC Relying Party, nonce is generated and stored. Whereas for UAM as SAML Service Provider, UAM stores the SAML assertion/response ID to prevent replay attack of the SAML assertion. This short-term data needs to be accessible by other UAM instances for it to be effective. When Ehcache is used (the default option), the elements/entries need to be replicated to other instances. Ehcache replicates the data via peer-to-peer RMI connection and multicast discovery. An alternative to Ehcache is to use Redis Cache, a distributed cache. The following sections explain about the Redis Cache and its configuration.

Redis Cache Provider

AccessMatrix has a Cache Provider abstraction layer that allows AccessMatrix modules, such as OIDC and SAML, to easily switch between Cache Provider (Ehcache or Redis Cache). While Ehcache is in general proven in term of performance due to its in-memory cache for on-premise deployment, it has its challenges when deployed in a cloud environment (e.g. due to multicast is not supported in cloud networking or not a best practice to have peer-to-peer communication). Redis Cache is designed for the cloud environment and has a distributed architecture by design. Many major cloud providers provide Redis Cache or have Redis Cache interface for applications to use. The distributed nature also works well where there are many AccessMatrix instances that are deployed.

Ehcache and Redis Comparison

- **Ehcache**
 - In-memory within the AccessMatrix instance; thus, it is faster.
 - No extra component is needed as Ehcache is embedded within AccessMatrix.
 - Difficult or not suitable for cloud deployment.
 - Replication delay may require the application to introduce a workaround to allow replication to take place.
 - **Redis Cache**
 - Distributed by design, which is suitable for cloud deployment.
 - It scales well and provides more consistent result when accessed by multiple AccessMatrix instances.
 - Major cloud providers have Redis Cache service or Redis Cache-compatible interface.
-

Configure Redis Cache Provider

By default, AccessMatrix server is using Ehcache as the cache provider. To use Redis cache, perform the following steps:

1. Navigate to the directory `<ACMATRIX_ROOT>\tomcat\webapps\am5\WEB-INF\classes`.
2. Open the **amsystem.properties** file.
3. Look for Cache Provider Configuration. Then, uncomment the following property list and modify the values, if necessary:

Properties (.properties files)

```
# == Cache Provider Configuration ==
#choose redis or ehcache, if not set, default is
ehcache
am.cache.vendor=redis
am.redis.host=127.0.0.1
am.redis.port=6379
#optional, don't set if no password required
#am.redis.password=xxxx
#optional, default is false
#am.redis.ssl.enabled=false
#optional, default is 8
#am.redis.pool.maxTotal=8
#optional, default is 8
#am.redis.pool.maxIdle=8
#optional, default is 3000
#am.redis.pool.maxWaitMillis=3000
```

4. Save the changes made.

7. Appendices

A. UAM Sample Report Templates

Enterprised SSO & Web SSO Report Sample

Printed Date : 2019-09-17 17:01:02

Time zone : SGT

Page : 1 / 1



Application Summary By Segment Report

Report Filtering Criteria

Segment Id : All Segment Name : All

Segment Id	Segment Name	Hierarchical Path	Number of Application Security Agent	Number of Web Security Agent	Number of USO Application	Total Applications
RootSegment	RootSegment	RootSegment	0	0	0	0
SampleSegment1	SampleSegment1	RootSegment/ SampleSegment1	0	1	0	1
SampleSegment1.1	SampleSegment1.1	RootSegment/ SampleSegment1/ SampleSegment1.1	0	0	0	0
SampleSegment1.2	SampleSegment1.2	RootSegment/ SampleSegment1/ SampleSegment1.2	0	0	0	0
SampleSegment1.3	SampleSegment1.3	RootSegment/ SampleSegment1/ SampleSegment1.3	1	0	0	1
SampleSegment1.4	SampleSegment1.4	RootSegment/ SampleSegment1/ SampleSegment1.4	0	0	0	0
SampleSegment1.5	SampleSegment1.5	RootSegment/ SampleSegment1/ SampleSegment1.5	0	0	0	0
SampleSegment1.6	SampleSegment1.6	RootSegment/ SampleSegment1/ SampleSegment1.6	0	0	0	0
SampleSegment1.7	SampleSegment1.7	RootSegment/ SampleSegment1/ SampleSegment1.7	0	0	0	0
SampleSegment2	SampleSegment2	RootSegment/ SampleSegment2	0	0	0	0
SampleSegment2.1	SampleSegment2.1	RootSegment/ SampleSegment2/ SampleSegment2.1	0	0	0	0
SampleSegment2.2	SampleSegment2.2	RootSegment/ SampleSegment2/ SampleSegment2.2	0	0	0	0

User Web SSO Privilege Report Sample

Printed Date : 2019-09-17 17:50:14

Time zone : SGT

Page : 1 / 1



User Web SSO Privilege Report

Report Filtering Criteria

User Store : Default Store

User Id : All

User Id	: demouser	Segment Id	: -	User name	: Demo User
Description	: Initial Demo User			Account Status	: Activated
Access Agent Id	Role	Start Time	End Time	Group Id	
ASApp1	ASARole	-	-	group1	
User Id	: user1	Segment Id	: -	User name	: user1
Description	: -			Account Status	: Activated
Access Agent Id	Role	Start Time	End Time	Group Id	
wsaApp1	wsaRole1	-	-	-	

Failed Web SSO Authorization By Application Resource Report Sample

Printed Date : 2019-09-18 16:57:14

Time zone : CST

Page : 1 / 1



Failed Web SSO Authorization By Application Resource Report

Report Filtering Criteria

User Store	: All	IP Address	: -
Actor User Id	: All		
Event Start	: 2019-09-01 00:00:00	Event End	: 2019-09-18 16:57:20
Client Id	: -	Sorted Order	: Actor User Id
Query Limit	: 1000	Is Query Result Exceeding Query Limit	: false
Access Agent Id	: All		

Access Agent Id	Resource				: /private/*		
Audit Id (Server Id)	Actor User Id@User Store	Reported Time	Actor IP Address	Client Type	Client Id	Method	Message
540 (AMClient)	kkwsa1@DefaultStore	2019-09-17 14:28:21	172.16.20.123	XML RPC	AG	POST	Authz for application=AG resource=/private/* method=POST failed: NoPrivilege (Authorization exception): Forbidding rules (if any): []
548 (AMClient)	kkwsa1@DefaultStore	2019-09-17 14:30:39	172.16.20.123	XML RPC	AG	POST	Authz for application=AG resource=/private/* method=POST failed: NoPrivilege (Authorization exception): Forbidding rules (if any): []
571 (AMClient)	kkwsa1@DefaultStore	2019-09-17 15:05:28	172.16.20.123	XML RPC	AG	POST	Authz for application=AG resource=/private/* method=POST failed: NoPrivilege (Authorization exception): Forbidding rules (if any): []
